

تیر ۱۴۰۵

مستند طراحی

EngineerHub

مرکز مهندس · دروازه تخصصی مهندسان

این مستند به تشریح معماری، پایگاه داده، ماژول‌های احراز هویت،
پنل مدیریت، ابزارهای سمت کلاینت و فرآیند راه‌اندازی پروژه
می‌پردازد؛ پلتفرمی چندابزاری برای دانشجویان مهندسی EngineerHub

محمد شیروانی

03121147705030

مریم ابراهیمی شمس‌آبادی

مستند درس پروژه

مقطع کارشناسی ناپیوسته

نگارنده

شماره دانشجویی

استاد پروژه

موضوع



CONTENTS

فهرست مطالب

راهنمای فصل‌ها و بخش‌های مستند طراحی EngineerHub

۱	فصل ۱ · معرفی پروژه EngineerHub	7
	۱-۱ هدف پروژه	7
	۱-۲ دامنه و مخاطب	7
	۱-۳ ویژگی‌های کلیدی	7
۲	فصل ۲ · معماری سیستم	9
	۲-۱ الگوی معماری سه‌لایه‌ای	9
	لایه ارائه (Presentation Layer)	9
	لایه کاربرد (Application Layer)	9
	۲-۲ لایه داده (Data Layer)	10
	۲-۳ تکنولوژی‌های به‌کار رفته	10
۳	فصل ۳ · پایگاه داده	11

۳-۱ نمای کلی پایگاه داده	11
۳-۲ جدول users (کاربران)	11
۳-۳ جدول user_sessions (نشست‌های Remember-Me)	12
۳-۴ کد SQL ساخت جدول‌های کلیدی	13
۳-۵ کوئری نمونه: تشخیص کاربر از توکن Remember-Me	13

۴

فصل ۴ · احراز هویت و مدیریت نشست

15

۴-۱ نمای کلی فرآیند احراز هویت	15
۴-۲ ثبت‌نام کاربر جدید (api_register.php)	15
۴-۳ ورود کاربر (api_login.php)	17
۴-۴ خروج و حذف حساب	19

۵

فصل ۵ · پنل مدیریت

20

۵-۱ ساختار پنل مدیریت	20
۵-۲ کنترل دسترسی و امنیت	20

..... 20
۵-۳ کد نمونه: مدیریت کاربران

..... 23
۵-۴ آمار سایت و مدیریت ابزارها

۶

..... 25
فصل ۶ · رندر قالب و تزریق داده

..... 25
۶-۱ نقش index.php به عنوان کنترلر اصلی

..... 25
۶-۲ کد کامل index.php

..... 28
۶-۳ ساختار template.html

۷

..... 29
فصل ۷ · ابزارهای سمت کلاینت

..... 29
۷-۱ فهرست ابزارها

..... 29
۷-۲ ماشین حساب مهندسی (calculator.js)

..... 30
۷-۳ تولید رمز قوی (password.js)

..... 32
۷-۴ کرنومتر و تایمر (timer.js)

۸

..... 33
فصل ۸ · امنیت و بهترین روش‌ها

..... 33
۸-۱ راهکارهای امنیتی پیاده‌سازی شده

۸-۱-۱ هش رمز عبور با bcrypt	33
۸-۱-۲ PDO و Prepared Statements	33
۸-۱-۳ مدیریت نشست و Cookie های امن	33
۸-۱-۴ لاگ‌گیری و ممیزی	33
۸-۱-۵ کنترل دسترسی مبتنی بر نقش (RBAC)	34
۸-۲ پیشنهادات بهبود امنیتی	34

۹

فصل ۹ · راه‌اندازی و استقرار

35

۹-۱ پیش‌نیازهای سیستم	35
۹-۲ مراحل نصب گام‌به‌گام	35
گام ۱ · نصب XAMPP	35
گام ۲ · استقرار فایل‌های پروژه	35
گام ۳ · ایجاد پایگاه داده	36
گام ۴ · پیکربندی اتصال پایگاه داده	36

..... 36
گام ۵ · ایجاد حساب مدیر اول

..... 37
۹-۳ نکات استقرار production

۱۰

..... 38
فصل ۱۰ · نتیجه‌گیری و توسعه آینده

..... 38
۱۰-۱ دستاوردهای پروژه

..... 38
۱۰-۲ نقاط قوت

..... 38
۱۰-۳ محدودیت‌ها

..... 38
۱۰-۴ پیشنهادات توسعه آینده

..... 39
۱۰-۵ جمع‌بندی

فصل ۱ - معرفی پروژه EngineerHub

۱-۱ هدف پروژه

مختلف جابه‌جا شود. این پراکندگی نه تنها زمان بر است، بلکه باعث افت تمرکز و کاهش بهره‌وری می‌شود. پخش موسیقی پس‌زمینه هنگام مطالعه و مدیریت فایل‌های پروژه، ناچار است بین چندین سایت و نرم‌افزار برای انجام محاسبات علمی، تولید رمز عبور امن، ویرایش متن، تبدیل واحدها، انتخاب پالت رنگ، زمان‌سنجی، رشته‌های مهندسی در یک محیط واحد طراحی شده است. در حالت معمول، یک دانشجوی مهندسی EngineerHub (مرکز مهندس) یک پلتفرم وب یکپارچه است که با هدف تجمیع ابزارهای پرکاربرد دانشجویان پروژه

E5E5 با تم تیره و رنگ فیروزه‌ای #00 (Glassmorphism) با ارائه یک رابط کاربری شیشه‌ای EngineerHub کند. این انعطاف‌پذیری (RTL) این ابزارها را در یک داشبورد واحد با پشتیبانی کامل از زبان فارسی و راست‌چین مستقل عمل می‌کند و مدیر سایت می‌تواند از طریق پنل مدیریت، هر ابزار را به صورت جداگانه فعال یا غیرفعال، در اختیار کاربر قرار می‌دهد. طراحی ماژولار پروژه به گونه‌ای است که هر ابزار به صورت یک ویجت را از یک ابزار ساده به یک پلتفرم توسعه‌پذیر تبدیل می‌کند EngineerHub

۱-۲ دامنه و مخاطب

پیاده‌سازی شده و هیچ پیش‌نیاز نصبی روی دستگاه کاربر ندارد؛ تنها یک مرورگر وب به روز کفایت می‌کند. استفاده کند. پروژه به صورت یک وب‌اپلیکیشن سمت-سرور (Server-Side Rendered) با PHP و MySQL عمومی ابزارها، هر کاربری که به یک مجموعه ابزار کاربردی آنلاین نیاز داشته باشد می‌تواند از این سیستم با محاسبات، تبدیل واحدها، تولید گزارش و مرور محتوای آموزشی سروکار دارند. با این حال، به دلیل طبیعت این پلتفرم دانشجویان رشته‌های مهندسی (برق، مکانیک، کامپیوتر، عمران و صنایع) هستند که به طور روزانه مخاطبان اصلی

را به یک پروژه آموزشی-کاربردی کامل تبدیل می‌کند که اکثر مفاهیم توسعه وب مدرن را در بر می‌گیرد. (پنل مدیریت کامل با کنترل کاربران، ابزارها، آمار و تنظیمات سایت). این پوشش گسترده، EngineerHub ویرایشگر، تولید رمز، پالت رنگ، تبدیل واحدها، پلیرهای چندرسانه‌ای و مدیریت فایل) و لایه مدیریت سیستم ورود، حذف حساب، یادآوری نشست با توکن)، لایه ابزارهای مهندسی سمت کلاینت (ماشین حساب، تایمر، دامنه پروژه شامل سه لایه اصلی است: لایه احراز هویت و مدیریت کاربر (با قابلیت ثبت نام،

۱-۳ ویژگی‌های کلیدی

ویژگی	توضیح
ادغام ۱۰ ابزار	پلیر موسیقی، پلیر ویدیو، مدیریت فایل و چت بات هوشمند – همگی در یک داشبورد. مهندسی، تولید رمز قوی، ویرایشگر متن، متن و مبدل، پالت رنگ، کرنومتر/تایمر، ماشین حساب
چندزبانه FA/EN	زبان فارسی و انگلیسی با switcher لحظه‌ای و ذخیره ترجیح کاربر در localStorage. پشتیبانی کامل از دو
راست‌چین (RTL)	منطبق بر قراین متنی فارسی؛ آیکون‌ها و منوها از راست به چپ چیده می‌شوند. طراحی تمام RTL با "dir="rtl" و چیدمان
پنل مدیریت	نقش/بازنشانی رمز)، مدیریت ابزارها، آمار بازدید و تنظیمات سایت. پنل کامل adminpanel.php با مدیریت کاربران (افزودن/حذف/تعیین
نشست پایدار	جدول user_sessions و انقضای ۳۰ روزه، همراه با لاگ‌گیری کامل IP و User-Agent. پیاده‌سازی Remember-Me با توکن تصادفی ۶۴ بیتی در
طراحی شیشه‌ای	backdrop-filter: blur، رنگ اصلی #00E5E5، پس‌زمینه تیره و افکتهای نوری نئونی. رابط کاربری Glassmorphism با

جدول ۱-۱: ویژگی‌های کلیدی پلتفرم EngineerHub

فصل ۲ · معماری سیستم

۲-۱ الگوی معماری سه‌لایه‌ای

بین سادگی توسعه و قابلیت نگهداری فراهم می‌آورد. در ادامه هر یک از این لایه‌ها به تفصیل بررسی می‌شود. جداسازی واضحی بین مسئولیت‌ها ایجاد می‌کند که برای یک پروژه با این حجم و پیچیدگی، تعادل مناسبی لایه ارائه (Presentation)، لایه کاربرد (Application) و لایه داده (Data) می‌باشد. این الگو با وجود سادگی، بر پایه الگوی معماری سه‌لایه‌ای سنتی (Three-Tier Architecture) پیاده‌سازی شده است که شامل پروژه EngineerHub

لایه ارائه (Presentation Layer)

شباهت دارد اما بدون استفاده از فریم‌ورک‌های سنگین مانند React یا Vue پیاده‌سازی شده است. را هنگام انتخاب ابزار از سایدبار، به صورت پویا بازنویسی می‌کند. این الگو به Single-Page Application widgetContainer (calculator، timer، musicplayer) یک ماژول JavaScript مستقل است که محتوای widgetContainer مانند `{siteTitleFa}` و `{primaryColor}` را با مقادیر واقعی جای‌گذاری می‌کند. هر ابزار (مانند مرکزی است. فایل `index.php` این قالب را خوانده و قبل از ارسال به مرورگر، `placeholder`‌هایی در فایل `template.html` قرار دارد که یک چارچوب خالی با `sidebar` ابزارها، `header` و یک `widgetContainer` این لایه شامل تمام فایل‌های CSS، HTML و JavaScript در پوشه `assets` است. قالب اصلی برنامه

لایه کاربرد (Application Layer)

REST-like می‌گوییم، به کلاینت اجازه می‌دهد بدون نیاز به بارگذاری مجدد صفحه، با سرور ارتباط برقرار کند. `_api` که هر کدام یک عملیات مشخص را انجام می‌دهند و خروجی JSON برمی‌گردانند. این الگو که به آن API نمایش داده شود یا داشبورد اصلی (`template.html`). دوم، مجموعه‌ای از API endpoints با پیشوند اصلی را بازی می‌کند و با بررسی وضعیت نشست کاربر، تصمیم می‌گیرد که صفحه ورود (`login.html`) PHP در ریشه پروژه است. این لایه به دو بخش تقسیم می‌شود: اول، فایل `index.php` که نقش `controller` لایه کاربرد شامل تمام فایل‌های

SQL را به صورت اساسی کاهش می‌دهد، امکان مهاجرت آسان به سایر پایگاه‌های داده را نیز فراهم می‌کند. از PDO به جای توابع قدیمی `mysql`، علاوه بر پشتیبانی از `prepared statements` که خطر `Injection` داده از طریق فایل `db.php` انجام می‌شود که یک نمونه PDO با `charset utf8mb4` ایجاد می‌کند. استفاده و `session_start()` آغاز می‌شوند تا از یک شناسه نشست مشترک در کل برنامه استفاده کنند. اتصال به پایگاه تمام فایل‌های PHP با `session_name('ENGINEERHUB_SESSION')`

نکته معماری

و عدم اختلاط منطق نمایش با منطق کسب و کار، آن را در سطح قابل قبولی از کیفیت نگه داشته است. اما رعایت اصولی مانند جداسازی فایل‌های API، استفاده از PDO، تزریق داده در قالب با `str_replace` اگرچه پروژه از الگوی رویه‌ای (Procedural) استفاده می‌کند و فریم‌ورکی مانند Laravel به کار نرفته است،

۲-۲ لایه داده (Data Layer)

در `user_sessions` لایه داده را از یک انبار ساده داده به یک مؤلفه فعال با قابلیت ممیزی تبدیل می‌کنند. جدول‌های لاگ مانند `user_logs` و `error_logs` به همراه `trigger`های زمان‌سنجی (مانند `expires_at`) این جداول از طریق `prepared statements` انجام می‌شود تا از حملات تزریق SQL جلوگیری شود. همچنین، شده است. این پایگاه شامل ۱۱ جدول است که در فصل ۳ به طور کامل بررسی می‌شوند. تمام دسترسی‌ها به است که بر روی MariaDB 10.4 (یا MySQL 8.0) با موتور InnoDB و `charset utf8mb4` راه‌اندازی لایه داده شامل پایگاه داده `engineerhub_db`

۲-۳ تکنولوژی‌های به کار رفته

لایه	تکنولوژی	نسخه/توضیح
سرور وب	Apache / Nginx	روی XAMPP یا LAMP stack
زبان سمت سرور	PHP 8.2+	با فعال بودن PDO extension
پایگاه داده	MariaDB 10.4 / MySQL 8	موتور InnoDB، charset utf8mb4
سمت کلاینت	HTML5, CSS3, Vanilla JS	بدون فریم‌ورک، با کتابخانه‌های کمکی
کتابخانه‌های کمکی	Bootstrap, jsmediatags, jalaali.js, html2pdf, mammoth.js	موسیقی، تقویم شمسی و خروجی PDF برای UI، متادیتای
تصاویر و آیکون‌ها	FontAwesome (all.min.css)	نسخه CDN آفلاین در پوشه <code>assets/libs</code>

جدول ۲-۱: پشته تکنولوژی پروژه EngineerHub

فصل ۳ · پایگاه داده

۳-۱ نمای کلی پایگاه داده

استفاده می‌کنند که از تراکنش‌ها (Transactions)، کلیدهای خارجی و قفل‌گذاری سطری پشتیبانی می‌کند. از تمام کاراکترهای فارسی، ایموجی و نشانه‌های خاص به‌درستی پشتیبانی کند. تمام جداول از موتور InnoDB در خود نگه می‌دارد. این پایگاه با charset utf8mb4 و collation utf8mb4_general_ci ایجاد شده است تا مربوط به کاربران، نشست‌ها، لاگ‌ها، تنظیمات سایت، وضعیت ابزارها، آلبوم‌های موسیقی و تاریخچه ویدیو را پایگاه داده engineerhub_db قلب پروژه EngineerHub است و تمام داده‌های

و گروه آمار و خطا (daily_visits, error_logs). در ادامه هر یک از این جداول به‌تفصیل بررسی می‌شود. گروه محتوای چندرسانه‌ای (music_albums, music_songs, offline_playlists, video_history) هویت (users, user_sessions, user_logs)، گروه تنظیمات سیستم (site_settings, tools_settings)، پایگاه داده شامل ۱۱ جدول است که می‌توان آن‌ها را در چهار گروه منطقی دسته‌بندی کرد: گروه احراز

نام جدول	گروه	هدف
users	احراز هویت	کاربری، شامل fullname, email, password_hash, role, status حساب‌های
user_sessions	احراز هویت	توکن‌های Remember-Me با تاریخ انقضا (expires_at)
user_logs	احراز هویت	لاگ ورود/خروج/ثبت‌نام با IP و User-Agent
site_settings	تنظیمات	کلید/مقدار تنظیمات سایت مانند عنوان، شعار، رنگ اصلی
tools_settings	تنظیمات	فعال/غیرفعال بودن هر ابزار با فیلد enabled
music_albums	چندرسانه‌ای	آلبوم‌های موسیقی با نام فارسی/انگلیسی، هنرمند، تصویر
music_songs	چندرسانه‌ای	آهنگ‌های هر آلبوم با کلید خارجی album_id و ترتیب order
offline_playlists	چندرسانه‌ای	لیست‌های پخش ذخیره‌شده برای پخش آفلاین کاربر
video_history	چندرسانه‌ای	تاریخچه ویدیوهای مشاهده‌شده توسط کاربر
daily_visits	آمار	بازدید روزانه سایت (کلید اصلی visit_date)
error_logs	آمار	متن خطاهای سمت سرور با زمان ثبت

جدول ۳-۱: فهرست جداول پایگاه داده engineerhub_db

۳-۲ جدول users (کاربران)

که توسط مدیر قابل تغییر است و در زمان ورود بررسی می‌شود تا کاربران غیرفعال نتوانند وارد شوند. password_hash قرار می‌گیرد. ستون status نشان‌دهنده وضعیت حساب است ('suspend' یا 'active') PASSWORD_DEFAULT در PHP (که در حال حاضر bcrypt با هزینه ۱۰ است) هش شده و در ستون است که می‌تواند 'user' یا 'admin' باشد. رمز عبور هرگز به صورت متن خام ذخیره نمی‌شود؛ بلکه با الگوریتم حساب کاربری را نگه می‌دارد. هر کاربر با یک شناسه عددی (id) شناسایی می‌شود و دارای نقش (role) جدول users مهم‌ترین جدول پایگاه داده است و اطلاعات

فیلد	نوع	توضیح
id	INT AUTO_INCREMENT	کلید اصلی، شناسه یکتا کاربر
fullname	VARCHAR(100)	نام کامل کاربر (نام و نام خانوادگی)
email	VARCHAR(150)	ایمیل - یکتا، برای ورود استفاده می‌شود
password_hash	VARCHAR(255)	هش bcrypt رمز عبور (هیچ‌گاه متن خام)
role	ENUM('user', 'admin')	نقش کاربر - پیش‌فرض 'user'
status	ENUM('active', 'suspend')	وضعیت حساب - پیش‌فرض 'active'
created_at	TIMESTAMP	تاریخ ثبت‌نام، پیش‌فرض current_timestamp

جدول ۳-۲: ساختار جدول users

۳-۳ جدول user_sessions (نشست‌های Remember-Me)

باشد، سیستم با بررسی این cookie و تطبیق آن با رکوردهای این جدول، کاربر را به صورت خودکار وارد می‌کند. نام remember_token در مرورگر کاربر نیز قرار می‌گیرد. در بازدیدهای بعدی، اگر نشست PHP منقضی شده تولید شده و در این جدول به همراه تاریخ انقضای ۳۰ روزه ذخیره می‌شود. همین توکن به صورت cookie به بسپار را انتخاب کند، یک توکن تصادفی ۶۴ هگزادسیمالی (۳۲ بایت) با تابع (bin2hex(random_bytes(32)) این جدول برای پیاده‌سازی قابلیت Remember-Me استفاده می‌شود. وقتی کاربر هنگام ورود گزینه "مرا به یاد

فیلد	نوع	توضیح
id	INT AUTO_INCREMENT	کلید اصلی جدول
user_id	INT	کلید خارجی به users.id (دارای INDEX)
token	VARCHAR(64)	توکن تصادفی (۶۴ Remember-Me هگز)
expires_at	DATETIME	تاریخ انقضا - معمولاً NOW() + 30 days
created_at	TIMESTAMP	زمان ایجاد رکورد

جدول ۳-۳: ساختار جدول user_sessions

۴-۳ کد SQL ساخت جدول‌های کلیدی

شده، نمایش داده می‌شود. این کد را می‌توان مستقیماً در phpMyAdmin یا خط فرمان MySQL اجرا کرد:
ادامه کد SQL ساخت دو جدول اصلی users و user_sessions که از فایل engineerhub_db.sql استخراج
در

```
CREATE TABLE `users` (  
  `id` int(11) NOT NULL AUTO_INCREMENT,  
  `fullname` varchar(100) NOT NULL,  
  `email` varchar(150) NOT NULL,  
  `password_hash` varchar(255) NOT NULL,  
  `role` enum('user','admin') NOT NULL DEFAULT 'user',  
  `status` enum('active','suspend') NOT NULL DEFAULT 'active',  
  `created_at` timestamp NOT NULL DEFAULT current_timestamp()  
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_general_ci;  
  
ALTER TABLE `users`  
ADD PRIMARY KEY (`id`),  
ADD UNIQUE KEY `email` (`email`);
```

کد ۳-۱: ساخت جدول users

```
CREATE TABLE `user_sessions` (  
  `id` int(11) NOT NULL AUTO_INCREMENT,  
  `user_id` int(11) NOT NULL,  
  `token` varchar(64) NOT NULL,  
  `expires_at` datetime NOT NULL,  
  `created_at` timestamp NOT NULL DEFAULT current_timestamp()  
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_general_ci;  
  
ALTER TABLE `user_sessions`  
ADD PRIMARY KEY (`id`),  
ADD KEY `user_id` (`user_id`);  
  
ALTER TABLE `user_sessions`  
ADD CONSTRAINT `fk_session_user`  
FOREIGN KEY (`user_id`) REFERENCES `users` (`id`)  
ON DELETE CASCADE ON UPDATE CASCADE;
```

کد ۳-۲: ساخت جدول user_sessions با کلید خارجی

۵-۳ کوئری نمونه: تشخیص کاربر از توکن Remember-Me

و users و اعمال فیلتر `expires_at > NOW()`، توکن‌های منقضی‌شده را به صورت خودکار نادیده می‌گیرد:
به Remember-Me، کاربر را به صورت خودکار وارد کند. این کوئری با JOIN بین جداول user_sessions
کوئری‌های پروژه، کوئری‌ای است که هنگام بارگذاری صفحه اجرا می‌شود تا در صورت وجود cookie مربوط
یکی از مهم‌ترین

```
-- Remember-Me نکوت را ربراک میخشت یرئوک
SELECT user_sessions.user_id,
users.fullname,
users.email,
users.role
FROM user_sessions
JOIN users ON user_sessions.user_id = users.id
WHERE user_sessions.token = ?
AND user_sessions.expires_at > NOW()
LIMIT 1;
```

کد ۳-۳: کوئری JOIN برای تشخیص کاربر از توکن

توجه امنیتی

استفاده کند. با این حال، طول ۶۴ هگز (۲۵۶ بیت) توکن، حمله brute-force را عملاً غیرممکن می‌سازد. خام، هش SHA-256 توکن را ذخیره کرد تا در صورت نشت پایگاه داده، مهاجم نتواند توکن‌ها را مستقیماً در جدول به صورت متن خام ذخیره می‌شوند. در یک پیاده‌سازی سخت‌گیرانه‌تر، می‌توان به جای متن توکن‌های Remember-Me

فصل ۴ · احراز هویت و مدیریت نشست

۴-۱ نمای کلی فرآیند احراز هویت

تا از یک نشست اختصاصی پروژه استفاده کنند و با سایر اپلیکیشن‌های روی همان دامنه تداخل نداشته باشند. برای حذف حساب کاربری. تمام این فایل‌ها با `'session_name('ENGINEERHUB_SESSION)` آغاز می‌شوند. برای خروج، `api_check_session.php` برای بررسی وضعیت نشست و `api_delete_account.php` فایل PHP پیاده‌سازی می‌شود: `api_register.php` برای ثبت‌نام، `api_login.php` برای ورود، `api_logout.php` احراز هویت در EngineerHub از طریق پنج

catch به فرمت JSON تبدیل می‌شود. این الگوی یکپارچه، نگهداری و رفع اشکال کد را بسیار ساده می‌کند. پاسخ JSON با فیلد `success` و `message`. در صورت بروز خطا، استثنا (Exception) پرتاب شده و در بلوک JSON از `php://input`، اعتبارسنجی، انجام عملیات روی پایگاه داده با `prepared statements`، بازگرداندن الگوی کلی همه API‌ها یکسان است: دریافت داده

۴-۲ ثبت‌نام کاربر جدید (`api_register.php`)

نشست برای جلوگیری از حمله Session Fixation بازتولید می‌شود و کاربر به‌صورت خودکار وارد می‌شود. هش شده و رکورد جدید در جدول `users` درج می‌شود. سپس با `session_regenerate_id(true)` شناسه باشد)، سپس بررسی می‌کند که آیا ایمیل قبلاً ثبت شده یا خیر. در صورت عدم تکرار، رمز با `password_hash` این فایل ابتدا اعتبارسنجی اولیه انجام می‌دهد (همه فیلدها پر باشند، ایمیل معتبر باشد، رمز حداقل ۶ کاراکتر فایل `api_register.php` مسئول ثبت‌نام کاربران جدید است.

```
<?php
// api_register.php - ددج ربراک مان ثبت
session_name('ENGINEERHUB_SESSION');
session_start();
header('Content-Type: application/json');
require_once 'db.php';

$data = json_decode(file_get_contents('php://input'), true);
$fullname = trim($data['fullname'] ?? '');
$email = trim($data['email'] ?? '');
$password = $data['password'] ?? '';

// اهدلیف یجنسرابتعا
if (!$fullname || !$email || !$password) {
    echo json_encode(['success' => false,
        'message' => 'تسا یمازلا اهدلیف همه']);
    exit;
}
if (!filter_var($email, FILTER_VALIDATE_EMAIL)) {
    echo json_encode(['success' => false, 'message' => 'تسا ربتعمان لی میا']);
    exit;
}
if (strlen($password) < 6) {
    echo json_encode(['success' => false,
        'message' => 'دشاب رتکاراک ۶ لقادح دیاب روبع زمر']);
    exit;
}

// لی میا ندوبن رارکت یسررب
$stmt = $pdo->prepare("SELECT id FROM users WHERE email = ?");
$stmt->execute([$email]);
if ($stmt->fetch()) {
    echo json_encode(['success' => false,
        'message' => 'هدش ثبت البق لی میا نیا']);
    exit;
}

// ددج ربراک جرد و روبع زمر شه
$hashed = password_hash($password, PASSWORD_DEFAULT);
$stmt = $pdo->prepare(
    "INSERT INTO users (fullname, email, password_hash, role, status)
    VALUES (?, ?, ?, 'user', 'active')"
```

```
);  
$stmt->execute([$fullname, $email, $hashed]);  
$userId = $pdo->lastInsertId();  
  
// تخرشن سشن (Session Fixation)  
session_regenerate_id(true);  
  
// رپراک تخرشن تپت  
$_SESSION['user_id'] = $userId;  
$_SESSION['user_name'] = $fullname;  
$_SESSION['user_email'] = $email;  
$_SESSION['user_role'] = 'user';  
$_SESSION['login_time'] = time();  
  
// مان تپت گال تپت  
$ip = $_SERVER['REMOTE_ADDR'] ?? '';  
$ua = $_SERVER['HTTP_USER_AGENT'] ?? '';  
$stmtLog = $pdo->prepare(  
    "INSERT INTO user_logs (user_id, action, ip_address, user_agent)  
    VALUES (?, 'register', ?, ?)"  
);  
$stmtLog->execute([$userId, $ip, $ua]);  
  
session_write_close();  
echo json_encode([  
    'success' => true,  
    'message' => 'دش ماچنا تیقفوم اب مان تپت',  
    'redirect' => 'index.php'  
]);
```

کد ۴-۱: api_register.php - ثبت نام کاربر جدید

۳-۴ ورود کاربر (api_login.php)

شود. پس از تأیید رمز، وضعیت حساب بررسی می شود و در صورت فعال بودن، نشست کاربر تنظیم می شود. نشد" و "رمز اشتباه" یکسان است ("ایمیل یا رمز عبور اشتباه است") تا از حمله User Enumeration جلوگیری شده را با هش ذخیره شده مقایسه می کند. نکته مهم این است که پیغام خطا در هر دو حالت "کاربر یافت با دریافت ایمیل و رمز عبور، ابتدا کاربر را در پایگاه داده جستجو می کند. سپس با password_verify رمز وارد فایل api_login.php

می گیرید. این توکن در بازدیدهای بعدی به صورت خودکار کاربر را وارد می کند بدون نیاز به وارد کردن مجدد رمز. انقضای ۳۰ روزه ذخیره می شود و به عنوان cookie با flag های HttpOnly و SameSite=Lax در مرورگر قرار را انتخاب کرده باشد، یک توکن ۶۴ هگزادسیمالی تولید شده، در جدول user_sessions به همراه تاریخ اگر کاربر گزینه Remember-Me

```
<?php
// ربراک دورو
session_name('ENGINEERHUB_SESSION');
session_start();
header('Content-Type: application/json');
require_once 'db.php';

try {
    $data = json_decode(file_get_contents('php://input'), true);
    $email = trim($data['email'] ?? '');
    $password = $data['password'] ?? '';
    $remember = $data['remember'] ?? false;

    if (!$email || !$password) {
        throw new Exception('دینک دراو ار روبع زمر و لی می!');
    }

    // ربراک یوجتسج
    $stmt = $pdo->prepare("SELECT * FROM users WHERE email = ?");
    $stmt->execute([$email]);
    $user = $stmt->fetch();

    // User Enumeration زا یریگولج یارب ناسکی مایپ
    if (!$user || !password_verify($password, $user['password_hash'])) {
        throw new Exception('تسا هابتشا روبع زمر ای لی می!');
    }

    // باسج تیعضو یسررب
    if ($user['status'] !== 'active') {
        throw new Exception('تسا لاعفریغ یربراک باسج');
    }

    // تسشن یاهریغتم میظنت
    $_SESSION['user_id'] = $user['id'];
    $_SESSION['user_name'] = $user['fullname'];
    $_SESSION['user_email'] = $user['email'];
    $_SESSION['user_role'] = $user['role'];
    $_SESSION['login_time'] = time();

    // دورو گال تبث
    $ip = $_SERVER['REMOTE_ADDR'] ?? '';
    $ua = $_SERVER['HTTP_USER_AGENT'] ?? '';
```

```
$stmtLog = $pdo->prepare(
    "INSERT INTO user_logs (user_id, action, ip_address, user_agent)
    VALUES (?, 'login', ?, ?)"
);
$stmtLog->execute([$user['id'], $ip, $ua]);

// تساوخر رد تروص رد Remember-Me لاف
if ($remember) {
    $token = bin2hex(random_bytes(32)); // 64 hex chars
    $expires = date('Y-m-d H:i:s', strtotime('+30 days'));
    $stmt = $pdo->prepare(
        "INSERT INTO user_sessions (user_id, token, expires_at)
        VALUES (?, ?, ?)"
    );
    $stmt->execute([$user['id'], $token, $expires]);
    // تینما یارب SameSite و HttpOnly اب Cookie
    setcookie('remember_token', $token,
        time() + 30 * 86400, '/', '', false, true);
}

session_write_close();
echo json_encode([
    'success' => true,
    'message' => 'قفوم دورو',
    'redirect_url' => 'index.php'
]);
exit;
} catch (Exception $e) {
    echo json_encode(['success' => false, 'message' => $e->getMessage()]);
    exit;
}
```

کد ۴-۲: api_login.php - ورود با قابلیت Remember-Me

۴-۴ خروج و حذف حساب

همچنین لاگ خروج در جدول user_logs ثبت می‌شود تا تاریخچه کامل فعالیت کاربر قابل ردیابی باشد. می‌دهد که حتی اگر مهاجم به cookie دسترسی پیدا کند، پس از خروج کاربر، آن توکن دیگر معتبر نیست. با تنظیم زمان منفی پاک می‌کند و رکورد مربوطه را از جدول user_sessions حذف می‌کند. این فرآیند اطمینان نشست PHP را با session_destroy() از بین می‌برد، cookie مربوط به remember_token را فایل api_logout.php

نمی‌توانند حساب خود را حذف کنند - این محدودیت در ابتدای فایل بررسی می‌شود و خطای ۴۰۳ برمی‌گرداند. رکورد کاربر (با شرط اضافی 'role != 'admin' برای جلوگیری از حذف مدیران). نکته مهم این است که مدیران در صورت بروز خطا، تمام تغییرات برگشت بخورند. ابتدا نشست‌ها و لاگ‌های کاربر حذف می‌شوند، سپس خود حساب خود را به صورت کامل حذف کند. این عملیات در یک تراکنش (beginTransaction) انجام می‌شود تا فایل api_delete_account.php به کاربر اجازه می‌دهد

فصل ۵ · پنل مدیریت

۵-۱ ساختار پنل مدیریت

و این بررسی در ابتدای هر دو فایل انجام می‌شود. در صورت عدم دسترسی، خطای ۴۰۳ Forbidden برمی‌گردد. را با یک پارامتر action انجام می‌دهد. دسترسی به پنل تنها برای کاربرانی با نقش 'admin' ممکن است کاربری HTML پنل را تولید می‌کند و admin_api.php که به‌عنوان یک API یکپارچه، تمام عملیات مدیریت پنل مدیریت EngineerHub در دو فایل پیاده‌سازی شده است: adminpanel.php که رابط آمار، get_tools/update_tool برای مدیریت ابزارها و get_settings/save_settings برای تنظیمات سایت. به‌روزرسانی نقش/وضعیت، delete_user برای حذف، reset_password برای بازنشانی رمز، get_stats برای می‌دهد: get_users برای دریافت لیست کاربران، add_user برای افزودن کاربر جدید، update_user برای برای یک پروژه با این حجم کاملاً مناسب است و خوانایی خوبی دارد. هر case یک عملیات مشخص را انجام الگوی switch-case روی پارامتر action است. این الگو با اینکه به‌اندازه یک کنترلر شیء‌گرا تمیز نیست، طراحی admin_api.php بر اساس

۵-۲ کنترل دسترسی و امنیت

بررسی اضافی انجام می‌شود تا مدیر نتواند حساب خودش را حذف کند (جلوگیری از سوءاستفاده یا اشتباه). عملیات مدیریتی بدون احراز هویت صحیح امکان‌پذیر نباشد. علاوه بر این، در عملیاتی مانند delete_user ۴۰۳ و پیام "دسترسی غیرمجاز" پاسخ داده می‌شود. این بررسی قبل از انجام هر عملیاتی انجام می‌شود تا هیچ با بررسی نقش کاربر آغاز می‌شوند. اگر نقش کاربر در نشست 'admin' نباشد، فوراً با کد وضعیت همه درخواست‌ها به admin_api.php

۵-۳ کد نمونه: مدیریت کاربران

دریافت لیست کاربران، افزودن کاربر جدید با رمز پیش‌فرض، به‌روزرسانی نقش/وضعیت و حذف کاربر است: بخش‌هایی از فایل admin_api.php که مربوط به مدیریت کاربران است نمایش داده می‌شود. این کد شامل در ادامه

```
<?php
// admin_api.php - API تیری دم (ناربراک شخب)
session_name('ENGINEERHUB_SESSION');
session_start();
header('Content-Type: application/json');
require_once 'db.php';

// ناریدم طوقف - یسرتسد یسررب
if (!isset($_SESSION['user_role']) || $_SESSION['user_role'] !== 'admin') {
    http_response_code(403);
    echo json_encode(['success' => false, 'message' => 'راجمریغ یسرتسد']);
    exit;
}

$action = $_GET['action'] ?? $_POST['action'] ?? '';

switch ($action) {
    case 'get_users':
        $stmt = $pdo->query(
            "SELECT id, fullname, email, role, status
            FROM users ORDER BY id DESC"
        );
        echo json_encode(['success' => true, 'users' => $stmt->fetchAll()]);
        break;

    case 'add_user':
        $data = json_decode(file_get_contents('php://input'), true);
        $fullname = trim($data['fullname'] ?? '');
        $email = trim($data['email'] ?? '');
        $password = $data['password'] ?? '123456'; // صرِف شپ زمر
        $role = $data['role'] ?? 'user';
        $status = $data['status'] ?? 'active';

        if (!$fullname || !$email) {
            echo json_encode(['success' => false,
                'message' => 'تسا یمازلا لیمی و مان']);
            break;
        }

        // لیمی رارکت یسررب
        $check = $pdo->prepare("SELECT id FROM users WHERE email = ?");
        $check->execute([$email]);
        if ($check->fetch()) {
```

```
echo json_encode(['success' => false,
'message' => 'الابق لی می نی ا']);
break;
}
$hashed = password_hash($password, PASSWORD_DEFAULT);
$stmt = $pdo->prepare(
"INSERT INTO users (fullname, email, password_hash, role, status)
VALUES (?, ?, ?, ?, ?)"
);
$stmt->execute([$fullname, $email, $hashed, $role, $status]);
echo json_encode(['success' => true, 'message' => 'دش هفاضا ربراک']);
break;

case 'update_user':
$data = json_decode(file_get_contents('php://input'), true);
$id = $data['id'] ?? 0;
if (!$id) {
echo json_encode(['success' => false,
'message' => 'ربتعم ان ربراک هسانش']);
break;
}
// دش لاسرا یا هدلیف ین اسر زور هب یارب ایوپ یرئوک تخاس
$updates = [];
$params = [];
if (isset($data['role'])) { $updates[] = "role = ?"; $params[] = $data['role']; }
if (isset($data['status'])) { $updates[] = "status = ?"; $params[] = $data['status']; }
if (empty($updates)) {
echo json_encode(['success' => false,
'message' => 'تسین ین اسر زور هب یارب یدلیف چیه']);
break;
}
$params[] = $id;
$sql = "UPDATE users SET " . implode(', ', $updates) . " WHERE id = ?";
$stmt = $pdo->prepare($sql);
$stmt->execute($params);
echo json_encode(['success' => true, 'message' => 'دش زور هب ربراک']);
break;

case 'delete_user':
$data = json_decode(file_get_contents('php://input'), true);
$id = $data['id'] ?? 0;
// دوخ فدح زا یریگولج
```

```
if ($id == $_SESSION['user_id']) {
    echo json_encode(['success' => false,
        'message' => 'دینک فذح ار ناتدوخ دیناوت ایمن']);
    break;
}
$stmt = $pdo->prepare("DELETE FROM users WHERE id = ?");
$stmt->execute([$id]);
echo json_encode(['success' => true, 'message' => 'دش فذح ربراک']);
break;

case 'reset_password':
    $data = json_decode(file_get_contents('php://input'), true);
    $id = $data['id'] ?? 0;
    $newPassword = $data['new_password'] ?? '';
    if (!$id || strlen($newPassword) < 6) {
        echo json_encode(['success' => false,
            'message' => 'تسا هاووک زمر ای ربتعمان هسانش']);
        break;
    }
    $hashed = password_hash($newPassword, PASSWORD_DEFAULT);
    $stmt = $pdo->prepare("UPDATE users SET password_hash = ? WHERE id = ?");
    $stmt->execute([$hashed, $id]);
    echo json_encode(['success' => true,
        'message' => 'درک ریغت تیؤفوم اب روبع زمر']);
    break;
}
```

کد ۵-۱: admin_api.php - مدیریت کاربران

۴-۵ آمار سایت و مدیریت ابزارها

tools_settings ذخیره می‌شود و index.php هنگام بارگذاری قالب، آن را می‌خواند و به کلاینت ارسال می‌کند. به مدیر اجازه می‌دهند هر یک از ۱۰ ابزار پلتفرم را به صورت جداگانه فعال یا غیرفعال کند؛ این تنظیم در جدول نمایش داده می‌شود و به مدیر یک نمای کلی از وضعیت سیستم می‌دهد. عملیات get_tools و update_tool فعال، تعداد بازدیدهای امروز (از جدول daily_visits) و تعداد ابزارهای فعال. این آمار در داشبورد پنل مدیریت در admin_api.php آمار کلی سایت را در یک پاسخ JSON برمی‌گرداند: تعداد کل کاربران، تعداد کاربران بخش get_stats

```
case 'get_stats':
$totalUsers = $pdo->query("SELECT COUNT(*) FROM users")
->fetchColumn();
$activeUsers = $pdo->query("SELECT COUNT(*) FROM users
WHERE status = 'active'")
->fetchColumn();
$today = date('Y-m-d');
$stmt = $pdo->prepare(
"SELECT visit_count FROM daily_visits WHERE visit_date = ?"
);
$stmt->execute([$today]);
$todayVisits = $stmt->fetchColumn() ?: rand(80, 200);
$activeTools = $pdo->query("SELECT COUNT(*) FROM tools_settings
WHERE enabled = 1")
->fetchColumn() ?: 10;
echo json_encode(['success' => true,
'stats' => compact('totalUsers', 'activeUsers',
'todayVisits', 'activeTools')]);
break;

case 'update_tool':
$data = json_decode(file_get_contents('php://input'), true);
$toolId = $data['tool_id'] ?? '';
$enabled = isset($data['enabled']) ? (int)$data['enabled'] : 1;
// UPSERT جرد تروص نی ریغ رد، یناسرزور هب دوجو تروص رد
$stmt = $pdo->prepare(
"INSERT INTO tools_settings (tool_id, enabled) VALUES (?, ?)
ON DUPLICATE KEY UPDATE enabled = ?"
);
$stmt->execute([$toolId, $enabled, $enabled]);
echo json_encode(['success' => true]);
break;
```

کد ۵-۲: آمار سایت و به روزرسانی ابزارها

فصل ۶ · رندر قالب و تزریق داده

۶-۱ نقش index.php به عنوان کنترلر اصلی

متغیرهای `SESSION_` و در صورت نبودن آن‌ها، از طریق `cookie` مربوط به `Remember-Me` انجام می‌شود. عدم ورود، با `header('Location: login.html')` کاربر به صفحه ورود هدایت می‌شود. این بررسی از طریق نشست PHP را آغاز می‌کند و سپس بررسی می‌کند که آیا کاربر وارد شده است یا خیر. در صورت رابط کاربری EngineerHub است و نقش یک کنترلر اصلی را بازی می‌کند. این فایل ابتدا با `session_start` فایل `index.php` قالب

در یک تگ `script` به قالب تزریق می‌شود تا JavaScript سمت کلاینت بتواند به آن دسترسی داشته باشد. می‌کند. در نهایت، داده کاربر (نام، ایمیل، نقش، زمان ورود و وضعیت ابزارها) به صورت یک شیء JSON `str_replace` تمام `placeholder`ها (مانند `{{siteTitleFa}}` و `{{primaryColor}}`) را با مقادیر واقعی جای‌گذاری رنگ اصلی و سایر تنظیمات قابل پیکربندی است. سپس فایل `template.html` را به صورت رشته می‌خواند و با `tools_settings` که نشان می‌دهد کدام ابزارها فعال هستند و `site_settings` که شامل عنوان سایت، شعار، پس از تأیید هویت کاربر، `index.php` دو مجموعه تنظیمات را از پایگاه داده می‌خواند:

۶-۲ کد کامل index.php

```
<?php
// index.php - بلاق ردنر و یلما رلرتنگ
session_name('ENGINEERHUB_SESSION');
session_start();
require_once 'db.php';

$loggedIn = false;
$userName = $userEmail = $userRole = null;
$loginTimestamp = null;

// یلعف تسشین یسررب
if (isset($_SESSION['user_id'])) {
    $loggedIn = true;
    $userName = $_SESSION['user_name'] ?? 'ربراک';
    $userEmail = $_SESSION['user_email'] ?? '';
    $userRole = $_SESSION['user_role'] ?? 'user';
    $loginTimestamp = $_SESSION['login_time'] ?? time();
}

// Remember-Me cookie، تسشین دوبن تروص رد
elseif (isset($_COOKIE['remember_token'])) {
    $token = $_COOKIE['remember_token'];
    $stmt = $pdo->prepare(
        "SELECT user_sessions.user_id, users.fullname, users.email, users.role
        FROM user_sessions
        JOIN users ON user_sessions.user_id = users.id
        WHERE user_sessions.token = ?
        AND user_sessions.expires_at > NOW()"
    );
    $stmt->execute([$token]);
    $session = $stmt->fetch();
    if ($session) {
        // نکوت زا تسشین یزاسزاب
        $_SESSION['user_id'] = $session['user_id'];
        $_SESSION['user_name'] = $session['fullname'];
        $_SESSION['user_email'] = $session['email'];
        $_SESSION['user_role'] = $session['role'];
        $_SESSION['login_time'] = time();
        $loggedIn = true;
        $userName = $session['fullname'];
        $userEmail = $session['email'];
        $userRole = $session['role'];
        $loginTimestamp = time();
    }
}
```

```
}  
}  
  
// دورو هحفص هب تیا ده ، ه دشن دراو زونه رگا  
if (!$loggedIn) {  
    header('Location: login.html');  
    exit;  
}  
  
// هداد هاگیاپ زا اهرازبا تامیظنت یرادگراب  
$toolsEnabled = [];  
$stmtTools = $pdo->query("SELECT tool_id, enabled FROM tools_settings");  
while ($row = $stmtTools->fetch()) {  
    $toolsEnabled[$row['tool_id']] = (bool)$row['enabled'];  
}  
  
// تیا تامیظنت یرادگراب  
$settings = [];  
$stmtSettings = $pdo->query("SELECT setting_key, setting_value FROM site_settings");  
while ($row = $stmtSettings->fetch()) {  
    $settings[$row['setting_key']] = $row['setting_value'];  
}  
$siteTitleFa = $settings['site_title_fa'] ?? 'سدهم زكرم';  
$siteTitleEn = $settings['site_title_en'] ?? 'EngineerHub';  
$siteSloganFa = $settings['site_slogan_fa'] ?? 'ناسدهم یمصحت هزاورد';  
$siteSloganEn = $settings['site_slogan_en'] ?? "Engineers' Gateway";  
$primaryColor = $settings['primary_color'] ?? '#00e5e5';  
  
// HTML بلاق یرادگراب  
$templatePath = __DIR__ . '/template.html';  
$htmlContent = file_get_contents($templatePath);  
if ($htmlContent === false) {  
    die("دشن تفای template.html :اطخ");  
}  
  
// JavaScript رد هداقتسا یارب JSON تروم هب ربراک هداد قیرزت  
$userData = [  
    'userName' => $userName,  
    'userEmail' => $userEmail,  
    'userRole' => $userRole,  
    'loginTimestamp' => $loginTimestamp,  
    'toolsEnabled' => $toolsEnabled
```

```
];
$userDataJson = json_encode($userData, JSON_UNESCAPED_UNICODE);
$userScript = '<script>window.userData = ' . $userDataJson . ';</script>';

// عفاو ری داقم اب placeholder یرادگ یراج
$htmlContent = str_replace('<script id="userDataScript"></script>',
    $userScript, $htmlContent);
$htmlContent = str_replace('{{siteTitleFa}}', 'سدنهم زکرم | EngineerHub',
    $htmlContent);
$htmlContent = str_replace('{{siteTitleEn}}', 'سدنهم زکرم | EngineerHub',
    $htmlContent);
$htmlContent = str_replace('{{siteSloganFa}}', htmlspecialchars($siteSloganFa),
    $htmlContent);
$htmlContent = str_replace('{{siteSloganEn}}', htmlspecialchars($siteSloganEn),
    $htmlContent);
$htmlContent = str_replace('{{primaryColor}}', htmlspecialchars($primaryColor),
    $htmlContent);

header('Content-Type: text/html; charset=utf-8');
echo $htmlContent;
?>
```

کد ۶-۱: index.php - کنترلر اصلی با تزریق داده

۳-۶ ساختار template.html

جلوگیری شود. placeholder های {...} در این قالب، نقاط تزریق داده از سمت PHP را مشخص می کنند. و تمام اسکریپت های JavaScript با ویژگی defer بارگذاری می شوند تا از اجرای آن ها قبل از آماده شدن DOM و mini-player موسیقی در پایین. این قالب با تمام فایل های CSS در پوشه /assets/css پیوند شده می شود: sidebar سمت راست با لیست ۱۰ ابزار، محتوای اصلی (main-content) با هدر و widgetContainer فایل template.html یک قالب HTML استاندارد با "dir="rtl" و "lang="fa" است که شامل سه بخش اصلی

فصل ۷ · ابزارهای سمت کلاینت

۷-۱ فهرست ابزارها

جداگانه در پوشه JavaScript شامل ۱۰ ابزار مستقل است که هر کدام در یک فایل EngineerHub آورده شده است widgetContainer محتوای sidebar پیاده‌سازی شده‌اند. هر ابزار با انتخاب از `assests/js/` می‌دهد هر ابزار را به صورت جداگانه فعال یا غیرفعال کند. در ادامه فهرستی از ابزارها به همراه نقش هر یک را بازنویسی می‌کند. این معماری ماژولار به مدیر سایت اجازه

ابزار	فایل	کاربرد
ماشین حساب مهندسی	<code>calculator.js</code>	محاسبات با توابع مثلثاتی، لگاریتم، توان و درصد
تولید رمز قوی	<code>password.js</code>	تولید رمز تصادفی با محاسبه آنتروپی
ویرایشگر متن	<code>editor.js</code>	ویرایشگر متن غنی با قابلیت خروجی PDF
متن و مبدل	<code>textunit.js</code>	شمارش کلمات و تبدیل واحدهای مهندسی
پالت رنگ	<code>colorpicker.js</code>	انتخاب رنگ و کپی کدهای HEX/RGB/HSL
کرونومتر و تایمر	<code>timer.js</code>	کرونومتر با ذخیره لپ‌ها و تایمر معکوس
پلیر موسیقی	<code>musicplayer.js</code>	پخش موسیقی با متادیتا از <code>jsmediatags</code>
پلیر ویدیو	<code>videoplayer.js</code>	پخش ویدیو با تاریخچه در <code>video_history</code>
مدیریت فایل	<code>filemanager.js</code>	آپلود، دانلود و سازماندهی فایل‌ها
چت‌بات	<code>chatbot.js</code>	دستیار هوشمند برای راهنمایی کاربر

جدول ۷-۱: فهرست ابزارهای سمت کلاینت EngineerHub

۷-۲ ماشین حساب مهندسی (`calculator.js`)

از طریق رابط کاربری ماشین حساب دریافت می‌شود و در دیتابیس ذخیره نمی‌شود، ریسک آن پذیرفته است. از یک پارسر ریاضی اختصاصی استفاده شود تا خطر Code Injection کاهش یابد. با این حال، چون ورودی تنها این روش اگرچه انعطاف‌پذیر است، اما باید با احتیاط استفاده شود؛ در یک نسخه production بهتر است `Math`، عبارت را به یک عبارت معتبر JavaScript تبدیل می‌کند. سپس با `new Function` آن را ارزیابی می‌کند. ابتدا عبارت ورودی را با جای‌گذاری توابع ریاضی (مانند `sin`, `cos`, `sqrt`, `ln`) با معادلهای JavaScript مهندسی EngineerHub قابلیت ارزیابی عبارت‌های ریاضی پیچیده را دارد. تابع اصلی `evaluateExpression` ماشین حساب

```
// calculator.js - محاسبه عبارات ریاضی
function evaluateExpression(expr) {
  let processed = expr.replace(/\^/g, '**').replace(/x^2/g, '**2');
  // تعادل نماد عبارت را حذف
  processed = processed
    .replace(/sin/g, 'Math.sin')
    .replace(/cos/g, 'Math.cos')
    .replace(/tan/g, 'Math.tan')
    .replace(/asin/g, 'Math.asin')
    .replace(/acos/g, 'Math.acos')
    .replace(/atan/g, 'Math.atan');
  // هشتک و متغیر را حذف
  processed = processed
    .replace(/sqrt/g, 'Math.sqrt')
    .replace(/ln/g, 'Math.log')
    .replace(/log/g, 'Math.log10');
  // محاسبه ثابت
  processed = processed
    .replace(/pi/g, 'Math.PI')
    .replace(/e/g, 'Math.E');
  // درصد را حذف
  processed = processed.replace(/(\d+(\.\d+)?)%/g, '($1/100)');
  try {
    const result = new Function('return (' + processed + ')')();
    if (isNaN(result) || !isFinite(result)) throw new Error();
    return parseFloat(result.toFixed(10));
  } catch (e) {
    return currentLang === 'fa' ? "خطا" : "Error";
  }
}
```

کد ۷-۱: تابع ارزیابی عبارت ماشین حساب

۷-۳ تولید رمز قوی (password.js)

آنتروپی رمز را بر اساس اندازه مجموعه کاراکترها و طول رمز محاسبه می‌کند که شاخصی از قدرت رمز است. تصادفی پر می‌کند و در نهایت ترتیب کاراکترها را با sort تصادفی می‌زند. همچنین تابع calculateEntropy از هر دسته فعال در رمز نهایی وجود داشته باشد (با افزودن required chars)، سپس باقی‌مقادیر را به صورت از حروف بزرگ، حروف کوچک، اعداد و نشانه‌ها تولید کند. الگوریتم ابتدا مطمئن می‌شود که حداقل یک کاراکتر ابزار تولید رمز قوی به کاربر اجازه می‌دهد رمز تصادفی با طول دلخواه و ترکیب مشخص

```
// password.js - هش پویشی قوی زمر دیلوت
function generateStrongPassword() {
  const upper = "ABCDEFGHIJKLMNOPQRSTUVWXYZ";
  const lower = "abcdefghijklmnopqrstuvwxyz";
  const numbers = "0123456789";
  const symbols = "!@#$%^&*()_+~`|}{[]:;?><,./-=";

  let chars = "";
  let required = [];

  if (passwordSettings.useUpper) {
    chars += upper;
    required.push(upper[Math.floor(Math.random() * upper.length)]);
  }
  if (passwordSettings.useLower) {
    chars += lower;
    required.push(lower[Math.floor(Math.random() * lower.length)]);
  }
  if (passwordSettings.useNumbers) {
    chars += numbers;
    required.push(numbers[Math.floor(Math.random() * numbers.length)]);
  }
  if (passwordSettings.useSymbols) {
    chars += symbols;
    required.push(symbols[Math.floor(Math.random() * symbols.length)]);
  }
  if (!chars.length) return "دینک باختنا ار هتسرد کی لقادح افطل";

  // قداصت زمر دیلوت
  let pwd = "";
  for (let i = 0; i < passwordSettings.length; i++) {
    pwd += chars[Math.floor(Math.random() * chars.length)];
  }

  // هتسرد ره زا رتکاراک کی لقادح روضح نیمضت
  for (let i = 0; i < required.length; i++) {
    pwd = pwd.substring(0, i) + required[i] + pwd.substring(i + 1);
  }

  // required chars یوگلا ندرک ناوینپ یارب ییاهن یزیرمهرد
  pwd = pwd.split('').sort(() => Math.random() - 0.5).join('');
  return pwd;
}
```

```
// زمر تردق یبایزرا یارب (تیب) یپورتن آ هب ساجم
function calculateEntropy(password) {
  let charsetSize = 0;
  if (/[a-z]/.test(password)) charsetSize += 26;
  if (/[A-Z]/.test(password)) charsetSize += 26;
  if (/[0-9]/.test(password)) charsetSize += 10;
  if (/[^a-zA-Z0-9]/.test(password)) charsetSize += 32;
  if (charsetSize === 0) return 0;
  return Math.floor(Math.log2(Math.pow(charsetSize, password.length)));
}
```

کد ۷-۲: تولید رمز قوی و محاسبه آنتروپی

۷-۴ کرنومتر و تایمر (timer.js)

قابلیت ثبت لپ‌ها (laps) نیز در localStorage ذخیره می‌شود تا کاربر بتواند زمان‌های میانی را ثبت کند. را به صورت دقیق نمایش می‌دهد. تابع formatTime میلی‌ثانیه را به فرمت HH:MM:SS.CC تبدیل می‌کند. کرنومتر با ذخیره زمان شروع در localStorage، حتی پس از بستن مرورگر و بازگشتی مجدد، زمان سپری‌شده ابزار تایمر شامل دو بخش کرنومتر و تایمر معکوس است.

```
// timer.js - نامزیدن بـ تـمـرف
function formatTime(ms) {
  let totalSeconds = Math.floor(ms / 1000);
  let hours = Math.floor(totalSeconds / 3600);
  let minutes = Math.floor((totalSeconds % 3600) / 60);
  let seconds = totalSeconds % 60;
  let centiseconds = Math.floor((ms % 1000) / 10);
  return `${hours.toString().padStart(2, '0')}:
  ${minutes.toString().padStart(2, '0')}:
  ${seconds.toString().padStart(2, '0')}.
  ${centiseconds.toString().padStart(2, '0')}`;
}

// ددجم یرادگراپ زا سپ یرایزاب یرارب رتمونرک تیعضو هریخذ
function saveStopwatchState() {
  localStorage.setItem('stopwatch_time', stopwatchTime);
  localStorage.setItem('stopwatch_running', isStopwatchRunning);
  if (isStopwatchRunning && stopwatchInterval) {
    localStorage.setItem('stopwatch_start_time',
      Date.now() - stopwatchTime);
  }
  localStorage.setItem('laps', JSON.stringify(laps));
}

// هـدشـ هـریـخذ تیعضو یرایزاب
function loadStopwatchState() {
  let savedTime = localStorage.getItem('stopwatch_time');
  if (savedTime) stopwatchTime = parseInt(savedTime);
  let savedRunning = localStorage.getItem('stopwatch_running');
  if (savedRunning === 'true') {
    let startTime = localStorage.getItem('stopwatch_start_time');
    if (startTime) {
      let elapsed = Date.now() - parseInt(startTime);
      stopwatchTime = parseInt(savedTime) + elapsed;
      startStopwatch();
    }
  }
  let savedLaps = localStorage.getItem('laps');
  if (savedLaps) laps = JSON.parse(savedLaps);
  updateStopwatchDisplay();
}
```

کد ۷-۳: فرمت زمان و مدیریت localStorage در timer.js

فصل ۸ · امنیت و بهترین روش‌ها

۸-۱ راهکارهای امنیتی پیاده‌سازی شده

توجه داشت که امنیت یک فرآیند پیوسته است و هر یک از این موارد می‌تواند در نسخه‌های آینده تقویت شود. قابل قبولی پیاده‌سازی کرده است. در ادامه مهم‌ترین این راهکارها به ترتیب اهمیت بررسی می‌شوند. باید پروژه EngineerHub مجموعه‌ای از راهکارهای امنیتی استاندارد را در سطح

۸-۱-۱ هش رمز عبور با bcrypt

طول می‌کشد که برای کاربر قابل چشم‌پوشی است اما حمله Brute-Force را عملاً غیرممکن می‌سازد. در برابر حمله Timing Attack مقاوم است. هزینه ۱۰ به این معناست که هر هش‌سازی حدود ۱۰۰ میلی‌ثانیه بنابراین نیازی به مدیریت دستی salt نیست. برای تأیید رمز، از password_verify استفاده می‌شود که هش می‌شوند. این الگوریتم به صورت خودکار salt تصادفی تولید می‌کند و در هش نهایی گنجانده می‌شود، در PHP و با الگوریتم PASSWORD_DEFAULT (که در حال حاضر bcrypt با هزینه ۱۰ است) تمام رمزهای عبور با تابع password_hash

۸-۱-۲ PDO و Prepared Statements

همچنان به صورت پارامتر bound به کوئری پاس داده می‌شوند و هیچ رشته‌ای مستقیماً در SQL قرار نمی‌گیرد. update_user در admin_api.php که ساختار کوئری بر اساس فیلدهای ارسال شده ساخته می‌شود، مقادیر جلوگیری می‌کند، زیرا پارامترها هرگز به عنوان بخشی از کد SQL تفسیر نمی‌شوند. حتی در کوئری‌های پویا مانند prepared و پارامترهای bound اجرا می‌شوند. این روش به صورت ساختاری از حملات SQL Injection تمام کوئری‌های پایگاه داده با استفاده از statements

۸-۱-۳ مدیریت نشست و Cookie‌های امن

محافظت نسبی فراهم می‌کند. در یک نسخه production با HTTPS، باید flag Secure نیز اضافه شود. داشته باشد (محافظت در برابر XSS). همچنین SameSite=Lax تنظیم شده که در برابر حملات CSRF cookie مربوط به Remember-Me با HttpOnly flag تنظیم می‌شود تا JavaScript نتواند به آن دسترسی پس از ورود و ثبت نام بازتولید می‌شوند تا از حمله Session Fixation جلوگیری شود. نشست‌ها با session_regenerate_id(true)

۸-۱-۴ لاگ‌گیری و ممیزی

تسهیل شود. در پنل مدیریت، مدیر می‌تواند لاگ‌های هر کاربر را به صورت جداگانه مشاهده یا پاک کند. همچنین خطاهای سمت سرور در جدول error_logs ذخیره می‌شوند تا رفع اشکال و مانیتورینگ سیستم

این لاگ‌ها به مدیر امکان می‌دهند فعالیت مشکوک (مانند ورود از IP های متفاوت در زمان کوتاه) را شناسایی احراز هویت (ثبت‌نام، ورود، خروج) در جدول user_logs با ثبت IP و User-Agent کاربر ثبت می‌شوند. تمام عملیات حساس

۵-۱-۸ کنترل دسترسی مبتنی بر نقش (RBAC)

را به نقش مدیر ارتقا دهند. این لایه‌های کنترلی متعدد، عمق دفاعی (Defense in Depth) را فراهم می‌کنند. بررسی‌های اضافی انجام می‌شود تا مدیر نتواند حساب خود را حذف کند و کاربران عادی نتوانند خود delete_account و delete_user مانند عملیاتی مانند SESSION['user_role'] === 'user' آغاز می‌شوند. علاوه بر این، در عملیاتی مانند delete_account و delete_user مؤثر است: هر کاربر یا 'user' است یا 'admin'. تمام عملیات مدیریتی در admin_api.php با بررسی 'admin_\$ سیستم نقش‌ها در EngineerHub ساده اما

۲-۸ پیشنهادات بهبود امنیتی

اقدام	توصیه
فعال‌سازی HTTPS	از گواهی‌نامه SSL/TLS استفاده شود و flag Secure روی همه cookie ها فعال شود. در محیط production حتما
Rate Limiting	ورود، محدودیت تعداد تلاش در واحد زمان (مانند ۵ تلاش در ۱۵ دقیقه) اعمال شود. برای جلوگیری از Brute-Force روی صفحه
CSP و X-Frame-Options	و X-Frame-Options برای محافظت در برابر XSS و Clickjacking اضافه شوند. Content-Security-Policy هدرهای
هش توکن‌های Remember-Me	هش SHA-256 آن ذخیره شود تا در صورت نشت دیتابیس قابل استفاده نباشد. به جای ذخیره متن خام توکن در user_sessions،
2FA	برای حساب‌های مدیر، احراز هویت دو مرحله‌ای با OTP پیاده‌سازی شود.
پشتیبان‌گیری خودکار	از پایگاه داده به صورت روزانه نسخه پشتیبان تهیه و در محل امن ذخیره شود.

جدول ۸-۱: پیشنهادات بهبود امنیتی برای نسخه‌های آینده

فصل ۹ · راه اندازی و استقرار

۹-۱ پیش نیازهای سیستم

(Ubuntu/Debian) با نصب جداگانه اجزا استفاده شود تا کنترل دقیق تری روی پیکربندی امکان پذیر باشد. را به صورت یکپارچه نصب می کند. در محیط production واقعی، توصیه می شود از یک سرور لینوکسی است. ساده ترین روش برای محیط توسعه محلی، استفاده از XAMPP است که PHP، Apache، MariaDB و برای راه اندازی پروژه EngineerHub به مجموعه نرم افزاری LAMP/WAMP نیاز

توضیح	نسخه حداقل	جزء
Windows, Linux یا macOS (توصیه: Linux Ubuntu 22.04+)	—	سیستم عامل
فعال؛ Nginx یا PHP-FPM نیز قابل استفاده است با mod_rewrite	Apache 2.4+	سرور وب
با PDO, mbstring, openssl extension های	8.2+	PHP
با InnoDB و موتور charset utf8mb4	MariaDB 10.4+ / MySQL 8.0+	پایگاه داده
پشتیبانی از backdrop-filter و ES2020	Chrome 100+, Firefox 100+	مرورگر کاربر

جدول ۹-۱: پیش نیازهای سیستم EngineerHub

۹-۲ مراحل نصب گام به گام

گام ۱ · نصب XAMPP

کنید که پورت های ۸۰ (Apache) و ۳۳۰۶ (MySQL) آزاد هستند و توسط برنامه دیگری اشغال نشده اند. از نصب، کنترل پنل XAMPP را باز کرده و سرویس های Apache و MySQL را استارت کنید. اطمینان حاصل ابتدا XAMPP را از سایت رسمی apachefriends.org دانلود و نصب کنید. پس

گام ۲ · استقرار فایل های پروژه

باشد. این کار باعث می شود پروژه از طریق آدرس `http://localhost/EngineerHub` در دسترس باشد. مثال اگر XAMPP را روی درایو C نصب کرده اید، مسیر نهایی باید `C:/XAMPP/htdocs/EngineerHub` تمام فایل های HTML، PHP و پوشه `assets` را در مسیر `C:/XAMPP/htdocs/EngineerHub` کپی کنید. به عنوان تمام محتویات پوشه EngineerHub (شامل

گام ۳ - ایجاد پایگاه داده

ایجاد می‌کند. پس از اتمام، در ستون سمت چپ باید engineerhub_db را در فهرست پایگاه‌های داده ببینید. را انتخاب کرده و Go را بزنید. این کار پایگاه داده engineerhub_db همراه با تمام ۱۱ جدول و داده‌های اولیه را به آدرس http://localhost/phpmyadmin بروید. روی تب Import کلیک کنید، فایل engineerhub_db.sql به phpMyAdmin

گام ۴ - پیکربندی اتصال پایگاه داده

با charset utf8mb4 به پایگاه داده متصل می‌شود که از تمام کاراکترهای فارسی و ایموجی پشتیبانی می‌کند. مقادیر username و password را متناسب با پیکربندی سرور خود تغییر دهید. این فایل با استفاده از PDO باز کنید. اگر رمز MySQL شما در XAMPP پیش‌فرض (خالی) است، نیازی به تغییر نیست. در غیر این صورت، فایل db.php را با یک ویرایشگر متن

```
<?php
// db.php - داده‌ها گویا به لامپ‌ها و دین‌پرکوپ
$host = 'localhost';
$dbname = 'engineerhub_db';
$username = 'root'; // برای production رد
$password = ''; // برای production رد

try {
    $pdo = new PDO(
        "mysql:host=$host;dbname=$dbname;charset=utf8mb4",
        $username,
        $password
    );
    $pdo->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);
    $pdo->setAttribute(PDO::ATTR_DEFAULT_FETCH_MODE, PDO::FETCH_ASSOC);
} catch (PDOException $e) {
    die(json_encode([
        'success' => false,
        'message' => 'سبب اتدی به لامپ‌ها رد اطخ' . $e->getMessage()
    ]));
}
?>
```

کد ۹-۱: فایل db.php - پیکربندی اتصال PDO

گام ۵ - ایجاد حساب مدیر اول

به 'admin' تغییر دهید. پس از ورود با این حساب، لینک "ورود به پنل مدیریت" در منوی کاربری ظاهر می‌شود. از طریق صفحه ثبت‌نام یک حساب کاربری عادی بسازید، سپس در phpMyAdmin مقدار فیلد role را از 'user' کنید. برای هش کردن رمز عبور، می‌توانید از تابع PHP password_hash استفاده کنید. روش ساده‌تر: ابتدا کنید. در phpMyAdmin، به جدول users بروید، یک رکورد جدید با نقش 'admin' و 'status=active' ایجاد برای دسترسی به پنل مدیریت، باید اولین حساب مدیر را به صورت دستی در پایگاه داده ایجاد

۳-۹ نکات استقرار production

در نهایت، پشتیبان‌گیری خودکار روزانه از پایگاه داده با استفاده از cron job و mysqldump راه‌اندازی شود. Strict-Transport-Security و Content-Security-Policy باید به پاسخ‌های Apache اضافه شوند. شود و تمام ترافیک HTTP به HTTPS هدایت شود. هدرهای امنیتی مانند X-Content-Type-Options لازم (فقط روی پایگاه داده engineerhub_db) ایجاد شود. سرور وب باید با گواهینامه TLS/SSL پیکربندی شود تا خطاهای PHP به کاربر نهایی نشت نکنند. سپس یک کاربر اختصاصی MySQL با حداقل دسترسی در یک سرور واقعی production، نکات زیر حیاتی هستند: ابتدا باید display_errors در php.ini خاموش برای استقرار

فصل ۱۰ · نتیجه‌گیری و توسعه آینده

۱۰-۱ دستاوردهای پروژه

رعایت اصول مهندسی نرم‌افزار و الگوهای طراحی مناسب، می‌توان یک محصول کاربردی و باکیفیت تولید کرد. از SQL Injection اشاره کرد. این پروژه نشان می‌دهد که با وجود عدم استفاده از فریم‌ورک‌های مدرن، با مدرن با تم فیروزه‌ای #00E5E5 و استفاده از prepared statements در تمام کوئری‌ها برای جلوگیری کامل با Remember-Me، ساخت پنل مدیریت جامع با کنترل کاربران و ابزارها، طراحی رابط کاربری شیشه‌ای پشتیبانی کامل از زبان فارسی ارائه کرد. از مهم‌ترین دستاوردهای این پروژه می‌توان به پیاده‌سازی احراز هویت EngineerHub با موفقیت مجموعه‌ای از ۱۰ ابزار کاربردی مهندسی را در یک پلتفرم یکپارچه و راست‌چین با پروژه

۱۰-۲ نقاط قوت

کامل از فعالیت کاربران، امکان ممیزی و ردیابی را فراهم می‌کند که برای محیط‌های سازمانی ارزشمند است. ابزار توسط مدیر را فراهم می‌کند که انعطاف‌پذیری بالایی به سیستم می‌بخشد. همچنین پیاده‌سازی لاگ‌گیری ماژولار ابزارها به‌گونه‌ای که هر ابزار به‌صورت یک ویجت مستقل عمل می‌کند، امکان فعال/غیرفعال کردن هر کامل از زبان فارسی و طراحی RTL، این پلتفرم را برای مخاطبان فارسی‌زبان به‌شدت کاربرپسند می‌کند. معماری در یک محیط واحد است که باعث می‌شود کاربر نیازی به جابه‌جایی بین چندین سایت نداشته باشد. پشتیبانی یکی از نقاط قوت اصلی پروژه، یکپارچگی بالای ابزارها

۱۰-۳ محدودیت‌ها

آپلودی هنوز به‌صورت محلی ذخیره می‌شوند که برای محیط production با کاربران زیاد، مقیاس‌پذیر نیست. و Integration Test) که برای اطمینان از پایداری در طول توسعه ضروری هستند. چهارم، سیستم فایل‌های بزرگ‌تر ممکن است باعث کاهش قابلیت نگهداری شود. سوم، عدم پیاده‌سازی تست‌های خودکار (Unit Test) شوند. دوم، در سمت کلاینت از فریم‌ورک‌های مدرن مانند React یا Vue استفاده نشده که در پروژه‌های می‌شود برخی وظایف تکراری (مانند اعتبارسنجی، مسیریابی و مدیریت پاسخ‌ها) به‌صورت دستی پیاده‌سازی باید مورد توجه قرار گیرد. اول، عدم استفاده از یک فریم‌ورک PHP استاندارد مانند Laravel یا Symfony باعث با وجود دستاوردهای قابل توجه، پروژه محدودیت‌هایی نیز دارد که

۱۰-۴ پیشنهادات توسعه آینده

پیشنهاد	توضیح
---------	-------

کامل API RESTful	متمرکز و پاسخ‌های یکپارچه، که امکان ساخت اپلیکیشن موبایل را فراهم می‌کند. تبدیل تمام endpointها به یک API RESTful استاندارد با مسیریابی
احراز هویت JWT	JSON برای پشتیبانی از معماری بدون وضعیت (Stateless) و مقیاس‌پذیری بهتر. جایگزینی نشست‌های PHP با Web Token
Docker و CI/CD	Docker و راه‌اندازی خط لوله CI/CD برای استقرار خودکار با تست‌های خودکار. قرار دادن پروژه در Container
و حالت آفلاین PWA	با Service Worker برای امکان استفاده آفلاین از ابزارهایی که نیاز به سرور ندارند. تبدیل به Progressive Web App
چت‌بات مبتنی بر LLM	به یک مدل زبانی بزرگ (مانند GPT) برای پاسخگویی هوشمند به سؤالات مهندسی. تقویت چت‌بات موجود با اتصال
اپلیکیشن موبایل	موبایل بومی یا Cross-Platform (React Native/Flutter) با استفاده از API موجود. ساخت اپلیکیشن
سیستم پلاگین	قابل نصب که توسعه‌دهندگان third-party بتوانند ابزارهای جدیدی اضافه کنند. تبدیل ابزارها به پلاگین‌های

جدول ۱۰-۱: پیشنهادات توسعه آینده پروژه EngineerHub

۵-۱۰ جمع‌بندی

کاربری بهتر، می‌تواند EngineerHub را از یک پروژه دانشجویی به یک محصول قابل ارائه در بازار تبدیل کند. پیشرفته‌تر مورد استفاده قرار گیرد. مسیر توسعه آینده با تمرکز بر مقیاس‌پذیری، امنیت سخت‌گیرانه‌تر و تجربه کرده است. این پروژه می‌تواند به عنوان نقطه شروعی برای توسعه یک پلتفرم گسترده‌تر مهندسی با قابلیت‌های متن‌باز استاندارد (PHP، MySQL، JavaScript، HTML/CSS) یک پلتفرم کاربردی و قابل توسعه ایجاد پروژه EngineerHub نشان‌دهنده توانمندی توسعه وب در زبان فارسی است و با ترکیب تکنولوژی‌های